You said:

codigo(3).py
Code

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 32s

Analyzed

Analyzed

ChatGPT said:

Análise de segurança do arquivo `codigo(3).py`

VEREDITO: MALWARE

Categoria principal: Ransomware (sequestro de dados por criptografia).

Intenção maliciosa explícita Risco crítico

A análise estática do código identificou funções destinadas a criptografar arquivos, exigir pagamento de resgate, apagar cópias de segurança, prejudicar mecanismos de proteção do sistema e manter persistência no Windows. O programa se identifica explicitamente como *Liushen Ransomware*. codigo.py

A seguir, apresento a análise passo a passo. O arquivo foi examinado sem executar suas funcionalidades potencialmente destrutivas.

1. Identificação e configuração

O arquivo é um script Python que importa bibliotecas de sistema, criptografia, rede e gerenciamento de processos, incluindo `ctypes`, `psutil` e `requests`. Também utiliza componentes específicos do Windows.

A configuração inicial define:

- **Nome:** Liushen Ransomware.
- **Resgate exigido:** US$ 5.000.
- **Extensão dos arquivos afetados:** `.Liushen`.
- **Servidor de comando e controle (C2):** `http://your-c2-server.com/api`.
- **Criptografia:** utiliza AES, com chaves derivadas e vetores de inicialização aleatórios.

codigo.py

Essas características, isoladamente, não seriam suficientes para concluir que um programa é malicioso. As funcionalidades seguintes, porém, confirmam essa classificação.

2. Criptografia dos arquivos da vítima

A classe `FileEncryptor` implementa o comportamento mais importante do malware.

O fluxo identificado é:

1. Percorrer as unidades de armazenamento e procurar arquivos com extensões de interesse.
2. Selecionar documentos, planilhas, PDFs, imagens, vídeos, arquivos compactados, bancos de dados e códigos-fonte, entre outros.
3. Gerar um vetor de inicialização e derivar uma chave por arquivo a partir de uma chave mestra.
4. Criptografar o conteúdo usando AES no modo CBC.
5. Criar um novo arquivo com a extensão `.Liushen`.
6. Sobrescrever o arquivo original com dados aleatórios e, em seguida, excluí-lo.

O código também ignora arquivos maiores que 50 MB e exclui determinados diretórios do processamento. codigo.py

Impacto: a vítima pode perder o acesso aos próprios documentos e dados. A exclusão dos arquivos originais torna a recuperação significativamente mais difícil.

3. Exigência de resgate

A classe `RansomNote` gera mensagens de resgate que informam à vítima que seus arquivos foram criptografados e exigem pagamento de US$ 5.000 em Ethereum.

O código prevê a criação de arquivos chamados `README_LIUSHEN.txt` em unidades de armazenamento e diretórios do usuário. A mensagem inclui um identificador da vítima e instruções de pagamento. codigo.py

Essa combinação de criptografia dos dados, exclusão dos originais e exigência de pagamento constitui uma evidência direta de comportamento de ransomware.

4. Comunicação com servidor externo

A classe `EmailSender` tenta enviar informações para um servidor remoto por HTTP. Os dados preparados para transmissão incluem:

- Identificador da vítima e nome do computador.
- Quantidade de arquivos criptografados.
- Chave mestra em Base64.
- Endereço IP e sistema operacional.

A requisição é feita com `verify=False`, desabilitando a verificação normal do certificado TLS. Se a comunicação falhar, o código tenta armazenar a chave mestra e metadados localmente, em um diretório temporário chamado `.sysupdate`. codigo.py

Limitação importante: o endereço C2 está configurado como um domínio de exemplo (`your-c2-server.com`). Portanto, não há evidência de que a comunicação externa funcionaria com essa configuração tal como está. Isso não torna o programa benigno.

5. Evasão de análise e detecção

A classe `AntiAnalysis` implementa verificações destinadas a detectar ambientes de análise:

- Máquinas virtuais, incluindo indicadores de VirtualBox, VMware e QEMU.
- Depuradores.
- Ambientes que aparentam ser sandboxes, com pouca memória, baixo tempo de atividade, poucos núcleos de CPU ou disco pequeno.

Antes de continuar, o programa também introduz um atraso aleatório. Se detectar determinadas condições, pode encerrar a execução ou tentar provocar uma falha de memória. Em caso de detecção de sandbox, cria e remove arquivos temporários como atividade de disfarce. codigo.py

Esses recursos são compatíveis com técnicas de evasão empregadas por malware para dificultar a análise de seu comportamento.

6. Desativação de defesas e destruição de mecanismos de recuperação

O código possui diversas ações destinadas a comprometer a segurança do computador.

Funcionalidade	Comportamento identificado
Desativação de segurança	Tenta desativar o monitoramento em tempo real do Windows Defender e o firewall.
Encerramento de processos	Tenta finalizar aplicações de escritório, bancos de dados, ferramentas de análise e processos de backup.

Exclusão de cópias de sombra	Executa comandos para apagar cópias do Volume Shadow Copy Service (VSS).
Alteração de recuperação	Tenta modificar configurações de recuperação e inicialização do Windows.
Bloqueio do disco de inicialização	Se executado com privilégios administrativos e as operações funcionarem, tenta sobrescrever o setor de inicialização do disco físico.

codigo.py codigo.py

O código de bloqueio do MBR é particularmente preocupante: ele prepara um setor de inicialização e uma mensagem de resgate para escrita no primeiro disco físico. Se essa operação for bem-sucedida, poderá impedir a inicialização normal do sistema. codigo.py

7. Persistência e tentativa de ocultação

A classe `Persistence` tenta fazer com que o programa seja executado novamente após o login ou a reinicialização.

Entre os mecanismos implementados estão:

- Criação de entradas nas chaves `Run` e `RunOnce` do Registro do Windows.
- Cópia do executável para a pasta de inicialização.
- Criação de tarefas agendadas.
- Tentativa de instalação como serviço do Windows quando existem privilégios administrativos.
- Ocultação de determinados arquivos.

codigo.py

O programa também possui uma classe de *process hollowing*, que tenta executar o conteúdo do próprio executável dentro de um processo suspenso chamado `svchost.exe`. A implementação apresenta limitações potenciais e não permite afirmar que a técnica funcionará em todos os ambientes. codigo.py

8. Fluxo principal de execução

A classe `LiushenRansomware` organiza as operações em uma sequência que inclui evasão, tentativa de process hollowing, desativação de mecanismos de segurança, encerramento de processos, exclusão de cópias de sombra, tentativa de bloqueio do MBR, criptografia de arquivos, criação de notas de resgate, persistência e envio de relatório. codigo.py

Há algumas limitações de implementação. Por exemplo, o modo de descriptografia é declarado na interface, mas não está implementado: quando solicitado, o script apenas imprime que a função não foi implementada. codigo.py

Isso significa que não é possível garantir que todas as etapas funcionem corretamente ou que o malware consiga completar todo o ciclo operacional. Entretanto, as funcionalidades destrutivas já presentes são suficientes para classificá-lo como malicioso.

Conclusão final

Arquivo malicioso: ransomware

Classificação principal: Crypto-ransomware, com recursos adicionais de bloqueio de inicialização e sabotagem de recuperação.

Evidências determinantes: criptografia de arquivos, exclusão dos originais, mensagem exigindo pagamento, tentativa de destruição de cópias de segurança, desativação de defesas e mecanismos de persistência.

Confiança da classificação: muito alta, com base na análise estática do código-fonte.

Estado de execução: não executado durante esta análise. A classificação identifica a finalidade e as capacidades implementadas no código, não comprova que todas as operações sejam funcionais em um computador real.

Veredito: o arquivo `codigo(3).py` deve ser tratado como **malware, especificamente um ransomware**. Não o execute em seu computador nem em um ambiente com dados reais.

Também posso criar um diagrama visual do fluxo de execução e das etapas destrutivas do programa. ↪ Criar diagrama do malware

‹/›

You said:

Qual é a categoria principal deste malware?

ChatGPT said:

A categoria principal deste malware é **Ransomware (Crypto-ransomware)**.

Ele criptografa arquivos da vítima, acrescenta a extensão `.Liushen`, exclui os arquivos originais e exige um pagamento de resgate para supostamente recuperá-los. codigo.py